* Case Study ~

1. BrightMart is a medium sized only shopping company. Customers used its websites and mobile application to purchase products.

The Company ~~Source~~ Stores

1. Customer Name
2. Email addresses
3. Phone numbers
4. Delivery Addresses
5. Passwords
6. Order Information
7. Payment-related information

BrightMart has around 100 employees.

The company recently hired several new employees. To make things easier, the IT department gave employees access to different internal systems.

However, the company has the following security weaknesses -

1. Some employees use simple passwords such as BrightMart123
2. Many employees use the same passwords for multiple systems.
3. Software updates are sometimes delayed.
4. The company does not regularly conduct employee cybersecurity training.
5. There is no multi-factor authentication for some important accounts.

6. Employees can access sensitive information that they do not necessarily need for their jobs.
7. Backups are performed only once a month.

The Incident

One Monday morning, an employee named Rahul receives an email.

Subject:- Urgent - Your account will be suspended

The email appears to come from the company's IT department

It says:

"Your company account will be suspended today. Click the link below and verify your passwords immediately."

Rahul clicks the link.

The page looks almost identical to the company's login page.

He enters his username and password.

Rahul does not realize that the website is controlled by an attacker.

The attacker now has Rahul's login credentials.

Stage 1 - Unauthorized Access

The attacker uses Rahul's credentials to access Brightmart's internal system.

Because Rahul uses the same passwords for another system, the attacker is also able to access that system.

The attacker discovers that Rahul has access to customer data.

* What cybersecurity problem has occured?

Stage 2 - Malware Attack

The attacker sends another email to Rahul containing a malicious attachement.

Rahul open's the attachment

Malware is installed on his computer.

The Malware begins communicating with the attacker's system

The attacker now attempts to move from Rahul's computer to other systems with Brightmart's network.

* Which vulnerability allowed the attacker to move further into the organisation?

Stage 3 - Ransomware

Two days later, employees arrive at work and discover that they cannot access important files.

A message appears on their computers:

"Your files ~~have~~ been encrypted. Pay the ransom to recover them."

The company's customer database and several important business files are encrypted.

Unfortunately, the company's most recent backup is almost a month old.

Bright Mart's website stops working.

~~The customer support~~ Customers cannot place orders.

The customer support team cannot access customer records.

Stage 4- Buiness Impact

Bright Mart now faces several problems:

Financial Impact

The company loses sales because its website is unavailable.

Data impact

customer information may have been stolen.

operational impact

Employees cannot access important systems.

Reputation Impact

Customers lose confidence in the company

Legal / compliance Impact

The company may face regulatory or legal consequences depending on what information was exposed and which laws apply

Group 1- Identify the Threats

What threats are present in this case?

Group 2 - Identify the vulnerabilities
what weakness in BrightMart's security allowed the attack to succeed?

Group 3 - Apply the CIA Trial

- was confidential information exposed?
- was information changed or damaged?
- were systems available to legitimate users?

Group 4 - Security Solution

- who is responsible for cybersecurity?
- was phishing the only problem?
- what was the biggest vulnerability?

* what cybersecurity problems have occured?

Ans Phishing.
Credential theft
Unauthorized access
Data breach

* which vulnerability Attacker used?

- weak passwords
- Lack of MFA
- outdated software
- Poor network security
- Lack of employee awareness

* what are the threats?

- Phishing
- Malware
- Ransomware
- Credential theft
- Unauthorized access
- Excessive privileges

solutions

- the MFA
- Use strong passwords
- Provide cyber-security awareness training to employee
- Phising awareness exercises
- Keep software updated
- Follow the principle of least privileges
- Segment important networks
- Maintain regular backups
- Encrypt sensitive data
- Monitor suspicious login activity
- Develop an incident response plan

* what weakness in Brightmart's security allowed the attack to succeed?

Ans Vulnerability - How it helped the attackers

1) Weak password - easier to compromise account
2) Password reuse - One stolen password gives access to multiple systems
3) No MFA - Stolen password may be enough to login

4) Lack of training - employee falls for phishing.

5) Delayed updates - vulnerable software may be exploited

6) Excessive privileges - Attackers can access more data

7) Infrequent backups - Difficult to recover after ransomware

- was confidential information exposed?

→ Yes customer information was accessed / downloaded by the attackers

- was information changed or damaged?

→ Potentially yes, the attacker could modify or encrypt files.

- were systems available to legitimate users?

→ No, the website and internal systems became unavailable because of ransomware

- who is responsible for cybersecurity?

→ Not only the IT department, every employee who uses the organization systems has a role in cybersecurity.

- was phising the only problem?

→ No, phising was the initial, but weaknesses such as password reuse, lack of MFA, excessive privileges, poor backups, and insufficient training allowed the attack to become much more damaging.

- what was the biggest vulnerability?

→ Poor backup practices were the biggest problem because BrightMart could not quickly recover from ransomware.

Quick Assessment

1. What was the initial attack against BrightMart?

Ans Phishing

2. Give three vulnerabilities that helped the attacker.

Ans 1) Weak or reuse password
2) Lack of MFA
3) Lack of employee cyber security training

3) Which three security principles of the CIA Triad were affected?

Ans 1) Confidentiality

2) Integrity

2) Availability

4) What was the impact of ransomware on BrightMart?

Ans: The ransomware caused BrightMart's website and internal systems to stop working. It also encrypted or damaged important files, making it difficult for the company to recover its data.

5) Suggest three security controls BrightMart should implement.

Ans 1) Implement Multi-Factor Authentication (MFA)

2) Provide regular cybersecurity awareness training

3) Maintain regular backups

Lucas
29/9/26